Export nocturne : sauvegarde chiffrée et copie statistique

Référence : « Configuration du POS - B. Configuration Internet », §VII.B et tableau DAS (question « le POS nécessite une connexion Internet ») du manuel de certification. Cette annexe décrit une fonction **facultative** de `pili-pos`, absente tant que la section `export` de `pos.json` n'est pas renseignée.

> Cette annexe est la description du producteur. Elle ne rapporte aucune décision, avis ou approbation du SPF Finances : les procédures d'accès aux données du SPF Finances décrites dans `FEUILLE_ACQUISITION_DONNEES_FR.md` §2 restent celles du dossier.

---

1. Objet

Après chaque rapport Z réel, `pili-pos` peut produire deux copies des données de l'installation et les envoyer à un point de réception propre à l'installation :

1. une **sauvegarde chiffrée** de la base `pos.db` complète, que seul le propriétaire de l'établissement (et, en option, le producteur) peut déchiffrer ;
2. une **copie statistique** nettoyée des ventes de la période close, sans donnée personnelle directement identifiante, pour suivre l'activité (chiffre d'affaires, TVA, paiements, produits vendus).

Ces copies sont **hors de la chaîne de signature du FDM** : elles ne sont jamais envoyées au FDM, ne portent aucun numéro de séquence fiscal, n'influencent aucun compteur et ne modifient aucune table de `pos.db`. Elles ne remplacent ni le journal légal local (`fiscal_events`) ni la sauvegarde locale décrite dans `FEUILLE_ACQUISITION_DONNEES_FR.md` §1.2.

Code source : `crates/pos-export` (sauvegarde, chiffrement, copie statistique, envoi, file d'attente), `crates/pos-engine/src/commands/export.rs` (intégration au moteur), `crates/pos-core/src/config.rs` (section `export` de `pos.json`). Le contrat de la copie statistique est décrit pour les développeurs du récepteur dans `crates/pos-export/STATS_SCHEMA.md`.

2. Déclenchement

L'export est lancé :

- après **chaque rapport Z réel**, qu'il soit demandé par un Gérant (« Clôture journée ») ou produit automatiquement pour une journée restée ouverte (`MANUEL_UTILISATEUR_FR.md` §10) ;
- au démarrage du POS, pour tout Z réel postérieur au dernier export, dans la limite de `keep_days` jours (la caisse a pu être éteinte entre la clôture et l'export ; un Z plus ancien que `keep_days` jours est ignoré, test `a_z_older_than_keep_days_is_skipped_and_the_cursor_moves_past_it`) ;
- à la demande d'un Gérant (« Réessayer maintenant »), uniquement pour renvoyer des exports déjà préparés mais pas encore livrés.

Il n'a **jamais lieu en mode formation** : un Z de formation ne produit aucun export (test `a_training_z_exports_nothing`). À la première activation de la section `export`, seul le dernier Z déjà archivé est exporté, sans remonter l'historique.

Le nom de l'export est `<date comptable AAAAMMJJ>-z<numéro du Z sur 6 chiffres>`, par exemple `20261008-z000042`.

3. Une vente ou un Z n'est jamais retardé

L'export est une tâche de fond qui ne se met jamais en travers du fonctionnement fiscal :

- le chemin du Z ne fait que **réveiller** la tâche d'export après l'archivage et l'impression ; il n'attend ni sa fin ni son résultat ;
- la tâche lit `pos.db` par **sa propre connexion SQLite en lecture seule** (API Online Backup) : elle n'écrit rien dans la base ;

- elle ne prend **pas** le verrou de signature (celui qui sérialise les appels au FDM) ni le verrou de la base utilisé par les commandes de caisse ;
- elle s'exécute sur ses propres fils d'exécution ; une réception lente, injoignable ou en erreur n'a aucun effet sur la vente suivante ni sur le Z (test `a_receiver_that_takes_30_seconds_blocks_neither_the_z_nor_the_next` ;
- toute erreur d'export est consignée (journal et état visible, §10) et ne fait jamais échouer un Z ni une vente ; une section `export` invalide désactive l'export et rien d'autre (test `an_unusable_section_turns_the_export_off_a`

4. Les trois fichiers

Chaque export est un répertoire `exports/<identifiant>/` (sous le répertoire de données de l'installation) qui contient :

Fichier	Contenu
`pos-<identifiant>.db.age`	Copie cohérente complète de `pos.db`, chiffrée au format age.
`stats-<identifiant>.sqlite`	Copie statistique nettoyée de la période close par ce Z (§6).
`manifest-<identifiant>.json`	Manifeste de format `pili-export/1` : identifiant de l'export, `pos_id`, identifiant du terminal, version du logiciel, numéro du Z, date comptable, version du schéma statistique, clés publiques des destinataires, et pour chacun des deux autres fichiers son nom, sa taille et son empreinte SHA-256.

Un fichier `state.json` suit l'avancement de l'envoi (fichiers déjà livrés, nombre d'essais, prochain essai). Un export est construit dans un répertoire de travail puis déplacé à sa place quand il est complet : aucun export à moitié écrit n'est jamais visible ni envoyé (test `a_failure_leaves_no_partial_export_and_no_plaintext`). La copie en clair intermédiaire de la base n'existe que dans ce répertoire de travail, le temps du chiffrement.

5. Chiffrement de la sauvegarde et garde des clés

La sauvegarde est chiffrée avec **age** (format binaire, courbe X25519), avant tout envoi :

- **Destinataires** : la clé publique du **propriétaire de l'établissement** (obligatoire, `owner_recipient`) et, en option, la clé publique du **producteur** (`producer_recipient`). Chacun peut déchiffrer seul ; personne d'autre ne le peut (tests `owner_and_producer_both_decrypt_to_the_same_bytes` et `a_third_identity_cannot_decrypt` de `crates/pos-export/src/crypt.rs`).
- **Les clés privées ne sont jamais sur la caisse ni sur le serveur de réception.** La caisse ne reçoit que des clés publiques (dans `pos.json`). Le propriétaire génère sa paire de clés lui-même et garde la clé privée hors ligne (`MANUEL_INSTALLATION_FR.md` §4.2). Le serveur de réception ne détient la sauvegarde que sous forme chiffrée : **il ne peut pas la lire.** Il reçoit aussi la copie statistique et le manifeste, qui ne sont pas chiffrés (§6).
- **Aucune copie en clair de la base ne reste sur le disque** : la copie intermédiaire de la base est supprimée dès le chiffrement, et en cas d'échec à n'importe quelle étape ; le répertoire de travail est vidé au démarrage et avant chaque préparation (tests `no_plaintext_database_is_left_except_the_stats_files` et `the_backup_decrypts_to_the_database_and_the_manifest_verifies`).
- Perdre la clé privée du propriétaire (et celle du producteur, s'il y en a une) rend les sauvegardes déjà envoyées illisibles : ce risque est porté par le détenteur de la clé, c'est le prix du chiffrement de bout en bout.

La sauvegarde contient tout `pos.db`, donc des données personnelles (INSZ du personnel, données de clients des commandes en ligne si cette intégration est activée) : c'est pourquoi elle n'existe qu'en forme chiffrée hors de la caisse (`PROFIL_ENTREPRISE_FR.md` §6).

6. La copie statistique

La copie statistique est une base SQLite séparée, en version de schéma 1, qui décrit **une période comptable** : les ventes (événements `N`, remboursements compris) archivées dans la période et le rapport Z qui l'a close. Les montants sont ceux que le FDM a signés ; le producteur ne les recalcule pas à partir du menu.

6.1 Tables et colonnes (résumé)

Table	Contenu résumé
`meta`	Paires clé/valeur : format, version de schéma, identifiant de l'export, `pos_id`, terminal, version du logiciel, numéro de Z, date comptable, ouverture et clôture de la période, devise, date de génération.
`users`	Pseudonymes des utilisateurs présents dans le fichier (`user_ref`) et leur rôle (`admin`, `cashier`, `waiter`, `system`).
`tickets`	Une ligne par vente : numéro de ticket, type (`sale` ou `refund`), canal (`table`, `takeaway`, `delivery`, `online`), table, pseudonyme du vendeur, heure de signature, total, indicateur « sans paiement ».
`ticket_lines`	Lignes de ticket : code produit du menu, nom, rayon, quantité, prix unitaire, montant, remise, code TVA et taux.
`ticket_vat`	Calcul de TVA du FDM par ticket et par code TVA.
`ticket_payments`	Lignes de paiement : moyen (`cash`, `card`, `meal_voucher`, `app`, `online`, `other`), nature (`payment`, `rounding`, `tip`) et montant.
`ticket_discounts`	Changements de prix (remises, majorations) par ligne ou sur le ticket, sans le nom des promotions.
`z_report`	Le Z de la période : numéro, date comptable, nombre de ventes et de remboursements, total, pseudonyme de l'auteur (`system` pour un Z automatique).
`z_vat`	Totaux de TVA du Z, par code TVA.
`z_payments`	Totaux de paiement du Z, par moyen et par nature.

Les montants sont des entiers en centimes d'euro (signés : un remboursement est négatif), les taux de TVA des entiers en points de base, les dates des chaînes RFC 3339. Les totaux sont cohérents entre eux et avec le Z (le total des tickets égale le total du Z, la TVA par code égale `z_vat`, les paiements par moyen égalent `z_payments`) : les tests le vérifient (`counts_and_totals_match_the_fixture_and_the_z`, `vat_per_rate_equals_the_z`, `payments_match_the_tickets_and_the_z`). Le fichier ne contient pas les événements d'entraînement (`T`), les pointages (`S`), les copies (`C`), les commandes et additions (`P`), les mouvements de caisse et de tiroir (`F`), les factures (`I`), ni rien qui ne soit pas un événement fiscal de vente.

6.2 Pseudonymes des opérateurs

Un utilisateur n'est jamais désigné par son nom ni par son INSZ, mais par un **pseudonyme** `user_ref` : `system` pour l'identité système, ou `u–` suivi de 16 caractères hexadécimaux, empreinte SHA-256 de l'INSZ combiné à une **clé propre à l'installation**. Cette clé (32 octets aléatoires, créée une fois, mode 0600) reste sur la caisse : elle n'est jamais envoyée, n'est pas dans `pos.db` et n'est donc pas non plus dans la sauvegarde chiffrée. Celui qui ne détient que les fichiers statistiques ne peut pas remonter à une personne ni savoir si deux installations ont une personne en commun. Le même employé garde le même pseudonyme d'un jour à l'autre sur une installation (pour suivre les équipes), et un pseudonyme différent sur une autre. Un pseudonyme reste une donnée personnelle (`PROFIL_ENTREPRISE_FR.md` §6).

6.3 Ce qui est exclu

Le fichier ne contient jamais : INSZ ou numéro national, noms des employés, codes PIN (ni leur empreinte), jetons et secrets, adresses e-mail, numéros de téléphone, adresses postales, **données des clients des commandes en ligne** (nom, téléphone, adresse de livraison, notes, contenu reçu de HubRise), textes de tickets, signatures et données QR du FDM, numéros de TVA de clients, noms de promotions. Les colonnes de texte libre ne portent que des noms de produits et de rayons et des identifiants techniques.

Les tests l'imposent sur une base remplie exprès de ces données : l'ensemble des tables est exactement celui du contrat, aucun nom de colonne n'évoque une donnée personnelle, aucune valeur ne contient une suite de 11 chiffres, une arobase, une empreinte de PIN ou l'un des secrets plantés, et les octets du fichier ne les contiennent pas non plus (`the_table_set_is_exactly_the_documented_one`, `the_built_file_holds_no_personal_data`, `the_statistics_file_holds_no_personal_data`).

7. Transport

Les fichiers partent en **HTTPS** vers le point de réception **propre à l'installation** (`export.url`), à raison d'une requête PUT par fichier vers `<url>/<identifiant>/<nom du fichier>` :

- **Authentification** : un jeton porteur (`Authorization: Bearer`) lu à chaque passage dans un **fichier séparé** (`export.token_file`) ; le jeton n'est jamais dans `pos.json`, jamais dans un journal ni dans un message d'erreur (test `no_error_text_contains_the_token`).
- **Intégrité** : chaque requête porte l'empreinte **SHA-256** du fichier (en-tête `X-Content-SHA256`) ; le récepteur refuse un fichier dont l'empreinte ne correspond pas (test `a_wrong_hash_is_refused_by_the_receiver_with_`). Le manifeste répète ces empreintes.
- **Ordre** : sauvegarde, copie statistique, puis **manifeste en dernier** : le manifeste marque un export complet (test `a_complete_export_arrives_in_order_with_matching_hashes`).
- **Chiffrement du transport** : `https://` obligatoire ; le HTTP simple n'est accepté que vers la machine locale (`127.0.0.1`, `localhost`, `[::1]`) ou vers l'hôte de l'émulateur Android (`10.0.2.2`), pour les tests. Pas d'identifiants dans l'URL, ni de paramètres.
- **Limites** : délai de 120 secondes par fichier ; un fichier de plus de 512 Mio est refusé avec une erreur.
- **Aucun port entrant** n'est ouvert sur la caisse : c'est une seule connexion sortante HTTPS (port 443, ou le port indiqué dans `url`), seulement si la section `export` est renseignée.

8. Nouvelles tentatives et conservation

- Un envoi qui échoue (réseau, réponse autre que 2xx, délai dépassé) est repris après **1, 2, 4 minutes**, et ainsi de suite en doublant, plafonné à **60 minutes**, sans limite du nombre d'essais (test `failures_back_off_one_then_two_minutes_and_a_success_clears_the_error`). Un export interrompu reprend avec les seuls fichiers manquants (test `an_interrupted_export_resumes_with_the_missing_file`) et un export en échec ne retient pas le suivant (test `a_failing_export_does_not_hold_back_the_next_one`).
- Un Z fait pendant que la réception est en panne est envoyé après coup, y compris après un redémarrage de la caisse (test `a_z_made_while_the_receiver_is_down_is_uploaded_after_a_restart`).
- Les réponses 401 et 403 s'affichent comme « non autorisé » (jeton refusé) et sont réessayées de la même façon.
- Les exports locaux sont **conservés `keep_days` jours** (14 par défaut, de 1 à 365), envoyés ou non, puis supprimés. Un export jamais livré qui est supprimé ainsi est compté (« Abandonnés ») et journalisé. Cette suppression ne concerne que les copies de l'export : ni `pos.db`, ni `fiscal_events`, ni la sauvegarde locale du §1.2 de la feuille d'acquisition des données.

9. Stockage local

Les exports se trouvent sur le **disque interne** du kiosque, à côté de la base : dans le sous-répertoire `exports` de `/var/lib/pili-pos` (partition `/var` chiffrée LUKS2, `SECURITE_BD_FR.md` §3.6). **Ils ne sont jamais écrits sur une carte SD ni sur un autre support amovible.**

Ordre de grandeur de l'espace : chaque sauvegarde a la taille de `pos.db` (le chiffrement ne comprime pas), la copie statistique est bien plus petite que la base, et on garde `keep_days` exports : prévoir environ `keep_days` fois la taille de la base, en plus de la base elle-même et de ses 7 sauvegardes locales après Z.

10. État visible par le Gérant

L'état de l'export est réservé aux Gérants : bouton « Config », panneau « Export nocturne » (`MANUEL_UTILISATEUR_FR.md` §12.11).

Il indique : l'état (« Non configuré », « Configuration invalide », « À jour » ou « n exports en attente »), la destination (schéma, hôte et port seulement, sans chemin ni identifiant), le dernier export préparé, le dernier envoi complet, le prochain essai, la dernière erreur, le nombre d'exports conservés sur `keep_days` jours, le nombre d'exports abandonnés, et le bouton « Réessayer maintenant ». L'écran est rafraîchi toutes les 30 secondes tant qu'il est affiché. Les deux commandes (lecture de l'état, nouvel essai) sont refusées à toute session qui n'est pas Gérant (test `both_commands_refuse_a_session_that_is_not_an_admin`). Les fichiers d'état ne contiennent aucun secret (test `the_status_files_hold_no_secret`).

11. Configuration

La section facultative `export` de `pos.json` comporte :

Champ	Rôle
`url`	Point de réception propre à l'installation (`https://`).
`token_file`	Fichier qui contient le seul jeton porteur.
`owner_recipient`	Clé publique age du propriétaire (`age1...`).
`producer_recipient`	Facultatif : clé publique age du producteur.
`keep_days`	Facultatif : jours de conservation locale, 14 par défaut.

Section absente = export désactivé : rien n'est créé sur le disque, aucune connexion n'est ouverte (test `without_an_export_section_nothing_exists`). Une section mal formée (URL non sécurisée, clé qui n'est pas une clé age, durée hors de 1 à 365) est refusée par `pili-pos --check-config` (code de sortie 1), et si elle passe malgré tout, le moteur démarre normalement avec l'export désactivé et l'état affiche le problème. Voir `MANUEL_INSTALLATION_FR.md` §4.2 pour la procédure d'installation.

12. Ce que cela ne change pas

- Le **journal légal reste local** : `fiscal_events` dans `pos.db`, append-only, protégé par les déclencheurs SQLite (`SECURITE_BD_FR.md` §2.1). L'export est une copie ; il n'en devient jamais la source.
- Les **procédures d'accès aux données décrites dans le dossier** (`FEUILLE_ACQUISITION_DONNEES_FR.md` §2) sont inchangées : le contrôleur lit `pos.db` sur la caisse.
- **La sauvegarde complète ne quitte la caisse que chiffrée de bout en bout** pour le propriétaire. La copie statistique, elle, n'est pas chiffrée : elle est protégée par HTTPS pendant le transfert et le récepteur de l'installation peut la lire. Elle contient les montants de vente, de TVA et de paiement par ticket et par ligne, les numéros de ticket et les totaux des rapports Z, sans donnée directement identifiante, et les opérateurs y sont sous pseudonyme.
- Le POS **ne devient pas un POS dans le cloud** : la base reste locale, chaque vente est signée par le FDM sur le réseau local, et la caisse fonctionne identiquement sans Internet (l'export attend simplement son retour).
- Aucun changement de schéma de `pos.db`, aucun événement fiscal, aucun compteur, aucune requête au FDM ne dépend de l'export.

13. Tests qui le prouvent

Toutes les affirmations ci-dessus sont couvertes par des tests automatisés.

crates/pos-engine/tests/export_nightly.rs (moteur, contre un récepteur simulé) : a_sale_and_a_z_reach_the_re
a_real_z_starts_the_export_without_waiting_for_the_tick, a_receiver_that_takes_30_seconds_blocks_n
an_automatic_z_is_exported, a_training_z_exports_nothing, failed_uploads_are_retried_and_run_now_mal
a_wrong_token_is_reported_and_sales_go_on, without_an_export_section_nothing_exists,
an_unusable_section_turns_the_export_off_and_nothing_else, a_z_made_while_the_receiver_is_down_is_
both_commands_refuse_a_session_that_is_not_an_admin, the_statistics_file_holds_no_personal_data.

crates/pos-export/tests/outbox.rs (préparation, plus de copie en clair, rétention, état) : a_first_enable_exports_o
a_second_prepare_does_nothing, a_new_z_is_prepared, two_missed_zs_are_both_prepared_in_order,
a_z_older_than_keep_days_is_skipped_and_the_cursor_moves_past_it, no_plaintext_database_is_left_ex
a_failure_leaves_no_partial_export_and_no_plaintext, a_stats_build_error_leaves_nothing_either,
the_backup_decrypts_to_the_database_and_the_manifest_verifies, the_source_database_is_only_read,
retention_deletes_old_exports_and_counts_the_unsent_ones, the_status_files_hold_no_secret.

crates/pos-export/tests/outbox_upload.rs (envoi, reprise, délais) : a_complete_export_arrives_in_order_with
exports_go_out_in_id_order, failures_back_off_one_then_two_minutes_and_a_success_clears_the_error,
the_backoff_keeps_doubling_up_to_an_hour, a_refused_token_shows_as_unauthorized, an_interrupted_exp
a_failing_export_does_not_hold_back_the_next_one, retry_now_makes_a_backed_off_export_due,
an_unreadable_token_ends_the_pass_with_an_error_and_sends_nothing, retention_counts_only_the_unsen

crates/pos-export/tests/upload.rs (client HTTPS) : uploads_a_file_and_the_receiver_stores_the_exact_byt
a_wrong_token_is_unauthorized_and_nothing_is_stored, a_wrong_hash_is_refused_by_the_receiver_with_
a_slow_answer_past_the_client_timeout_is_a_transport_error, a_file_above_the_limit_is_too_large_an
no_error_text_contains_the_token, the_request_carries_the_contract_headers.

crates/pos-export/tests/stats_build.rs et **crates/pos-export/tests/stats_privacy.rs** (copie statistique) : counts_and_totals_match_the_fixture_and_the_z, vat_per_rate_equals_the_z, payments_match_the_tickets_and_the_z, channels_tables_kinds_and_users_follow_the_orders,
only_the_sales_of_the_period_are_exported, two_builds_of_the_same_input_have_the_same_content,
another_key_changes_the_pseudonyms_and_nothing_else, the_table_set_is_exactly_the_documented_one,
the_document_lists_every_table_and_column_and_nothing_else, the_built_file_holds_no_personal_data,
the_proof_catches_a_forbidden_column_name, the_proof_catches_a_leaking_value, the_proof_catches_a_s